



Darkly

Summary: This project is an introduction to cyber security in the field of the Web

Version: 6.0

Contents

I	Preamble	2
II	Introduction	3
III	Objectives	4
IV	General instructions	5
V	Mandatory part	6
VI	Bonus part	8
VII	Submission and peer-evaluation	9

Chapter I

Preamble



Chapter II

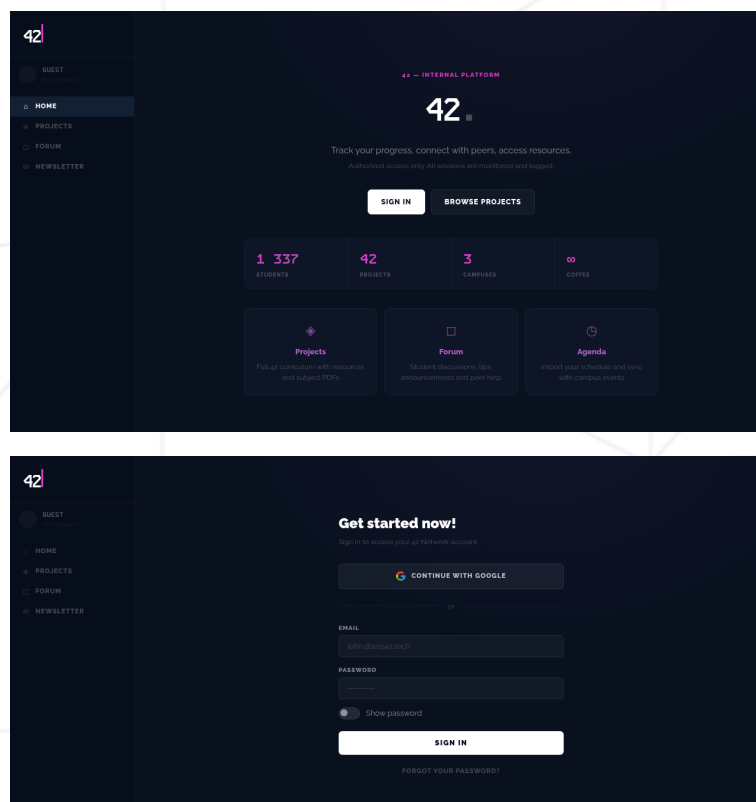
Introduction

When you develop your first websites, you will have absolutely no clue about the risks they will be exposed to on the World Wide Web.

This little project is here to teach you the basics: you will learn about these risks and vulnerabilities while auditing a simple website. This website demonstrates breaches, some of which still appear on well-established websites you visit on a daily basis.

Here is a major introduction to general vulnerabilities you will encounter on the World Wide Web.

In total, this platform contains **19 vulnerabilities** and hides **10 flags**. The mandatory and bonus parts below state how many of each you must recover and explain.



Chapter III

Objectives

This project aims to introduce you to cybersecurity in the field of the WWW.

You will discover OWASP, which is simply the largest cybersecurity project to date.

You will also learn what many frameworks do for you, automatically and transparently.

Chapter IV

General instructions

- This project will be reviewed by humans.
- You might have to prove your results during your evaluation. Be ready to do so.
- To validate this project, you will have to use the virtual-machine appliance provided with this subject (.ova format). Import it into VirtualBox and start it. The appliance is sealed: there is no login to perform. Once it has finished booting, its console displays the URL where the target application is served:

```
=====
Darkly v2 - 42 Security Project
      by @wil
=====

The application is running.

Open it in your browser:

    http://<vm-ip>:4942

VirtualBox NAT (default): from your host open:
    http://localhost:4942

This console is sealed - no login is available.
```

- Just open the displayed URL in your web browser to start the challenges. With VirtualBox's default NAT networking, the application is also reachable from your host at `http://localhost:4942`.
- Please inform the educational team if you find a bug!



The target is the web application served at the URL above, and nothing else. Do not attack, mount or decompile the .ova file, and do not try to break into the virtual machine or its operating system: there is nothing to find that way. The whole point of Darkly is to exploit the web site and to understand its vulnerabilities.

Chapter V

Mandatory part

- The platform hides **flags**. A flag is a unique token (of the form `FLAG{...}`) that you can only read once you have actually exploited the breach protecting it. A recovered flag is your proof that the breach really works.
- For the mandatory part you must, on this platform:
 - start with a **basic reconnaissance** of the platform to map its attack surface;
 - recover **6 flags**. **4 of them** are won by escalating your privileges **inside the web application**, step by step, until you **become its administrator** (the highest-privileged account of the application, not root on the machine): each privilege level you reach along the way gives you one flag. The **2 others** are flags of your choice, among the remaining weaknesses you uncover;
 - find, and clearly explain, **10 different vulnerabilities** of the platform (these include the breaches that protect your 6 flags), covering how each one works, the impact it has, and how it could have been avoided.
- Recovering the flags forces you to chain several of these vulnerabilities together. You must be able to explain every breach you go through during the evaluation.
- Every vulnerability you present is demonstrated **the same way**: a **script** that reproduces the exploitation, together with a written **explanation**. Some breaches yield a flag, some do not: that is the only difference between them.
- A typical layout is **one folder per breach**, named after it, containing your exploitation script, your explanation, any resources you need, and a **flag** file when the breach yields one. On top of that, you will provide a single **combined walk-through** of your whole audit, in the document format of your choice (Markdown, PDF, ...), with **English preferred**. Your repository could look like this:

```
$> ls
```

```
walkthrough.md {Breach name} [..]
```

```
$> ls -alR {Breach name}
{Breach name}:
drwxr-xr-x ... .
drwxr-xr-x ... ..
-rwxr-xr-x ... exploit.sh
-rw-r--r-- ... explanation.md
-rw-r--r-- ... flag
drwxr-xr-x ... Resources
```

```
{Breach name}/Resources:
drwxr-xr-x ... .
drwxr-xr-x ... ..
-rw-r--r-- ... whatever.whatever
```

```
$> cat {Breach name}/flag | cat -e
FLAG{xxxxxxxxxxxxxxxxxxxxxxxxxxxx}$
$>
```

- Place everything needed to reproduce and prove your work during the evaluation in each breach's Resources folder.



WARNING: You must be able to perfectly explain everything that is included in your repository. It cannot include ANY binaries.

- If you need a specific file served by the project appliance, you will have to download it during the evaluation. You must not put it in your repository under any circumstances.
- If you're using a specific external software, you will have to set up the required environment (VM, Docker, Vagrant).
- During the evaluation, you may be asked how you would fix the breaches you have exploited. You are not expected to patch the application (you do not have its source code), but you must be able to explain the remediation you would apply. Understanding what you exploit is, of course, strongly recommended.
- Explaining what you do is often more important than the exploitation itself. Take the time to understand, and make sure you are understood.



Hey, smarty (or not-so-smarty) pants! You cannot rely on turn-key tools such as sqlmap to make the exploitation look trivial: the scripts you hand in must be your own, and you must be able to explain them in detail during the evaluation.

Chapter VI

Bonus part

Beyond the main progression, the platform hides more weaknesses that are not required to become administrator. For the bonus part you must recover **4 additional flags (10 flags in total)** and find, and clearly explain, **5 more vulnerabilities**: the 4 breaches that protect those bonus flags, plus one further weakness that exposes no flag. Hand them in exactly like the mandatory breaches (script, explanation, flag when any).



The bonus part will only be assessed if the mandatory part is PERFECT. Perfect means the mandatory part has been fully completed and works without any malfunctions. If you have not met ALL the mandatory requirements, your bonus part will not be evaluated at all.

Chapter VII

Submission and peer-evaluation

Submit your assignment in your `Git` repository as usual. Only the work inside your repository will be evaluated during the defense.

How you organize your repository is **entirely up to you**: the folder and file layout, the file names and the document formats are free, as long as your work is easy to navigate and you can explain all of it during the evaluation. The structure shown in the mandatory part is only a suggestion.